ALEPH 개인과제 8 — 내 소개 페이지에 패스키 달기

> 과제용으로 만들어 넣은 내용입니다. 실제 개인정보는 없습니다. 비공개 자리는 패스키로 로그인해야만 열리므로, 열린 모습과 시험 결과를 이 보고서 뒷부분의 캡처와 기록으로 남겼습니다.

- 결과 주소(누구나 열림): https://aleph-about-me-page-passkey.vercel.app/
- 소스 주소: https://github.com/SCA-cloudy/ALEPH-About-Me-Page-Passkey
- 이 문서에 쓰인 비공개 자리의 내용·계정은 모두 **과제용으로 만들어 넣은 것**이며, 실제 개인정보는 없습니다.
- 비공개 자리는 패스키로 로그인해야만 열리므로, 열린 모습과 시험 결과는 이 문서와 `evidence/` 캡처로 남겼습니다.

4줄 확인 방법

1. **어디로 가나요**: 시크릿 창에서 https://aleph-about-me-page-passkey.vercel.app/ 를 엽니다(로그인 없이).
2. **무엇을 하나요(3단계 이내)**: ① 첫 화면을 봅니다. ② 맨 아래로 내려가 "나만의 자리"를 봅니다(또는 위 메뉴의 PRIVATE). ③ 같은 주소 뒤에 `/api/private/items` 를 붙여 엽니다.
3. **무엇이 보이면 통과**: ① 공개 소개 페이지(과제 1번 내용) ② "패스키로만 열립니다"와 함께 비공개 내용 없이 "서버 응답 401 · 로그인하지 않은 상태" ③ `{"error":"unauthorized","message":"패스키로 로그인해야 볼 수 있습니다."}` (401)
4. **안 될 때**: 새로고침(Ctrl+Shift+R) 후 다시 확인합니다. 비공개 내용(ARCHIVE·ROADMAP·REVIEW의 문장)이 로그인 없이 보이면 불통과입니다. 확인하는 분의 기기에는 이 사이트의 패스키가 없어 로그인할 수 없고, 이미 주인이 있는 계정이라 새로 등록하려 해도 403으로 막히는 것이 정상입니다.

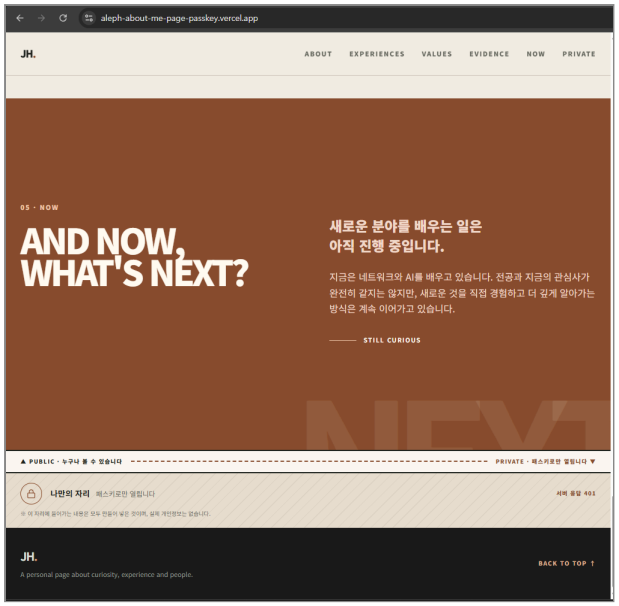
3줄 AI와 나

1. **AI에게 맡긴 일**: 등록·로그인·세션·삭제 코드와 서버의 서명 확인 로직 작성, 가상 인증기로 하는 자동 시험, 시험 기록과 증거 문서 정리.
2. **내가 직접 판단한 일**: 비공개 항목(ARCHIVE·ROADMAP·REVIEW)과 두 계정의 내용 정하기(A=보안·네트워크, B=커피), 메모장 기능을 넣지 않기로 한 것, 새 저장소·새 DB 프로젝트 결정, 실제 기기에서 등록·로그인·삭제·다른 계정 시험을 직접 실행해 결과 확인.
3. **AI 말을 안 들은 일**: 두 번째 패스키를 만들려고 AI가 제안한 Windows Hello PIN 설정을 하지 않았습니다(내 PC가 아니라서). 대신 PC 설정을 바꾸지 않는 방법(패스키마다 사용자 식별값을 다르게 하기)으로 해결했습니다.

남긴 증거 (다섯 묶음)

모두 배포 주소(https://aleph-about-me-page-passkey.vercel.app/)에서 일반 Chrome 창으로 직접 한 시험입니다. 시각은 2026-10-20(KST).

① 공개 영역과 비공개 영역을 가른 화면, 로그인 없이 받은 응답 본문

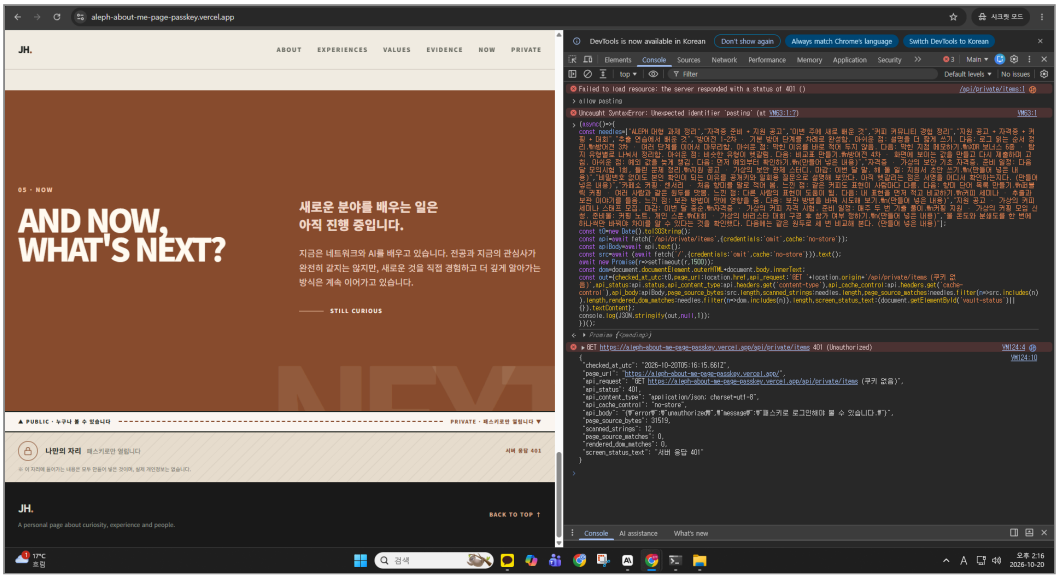


시크릿 창의 공개 페이지. 맨 아래 “나만의 자리”는 잠겨 있고 PUBLIC/PRIVATE 경계선이 보임



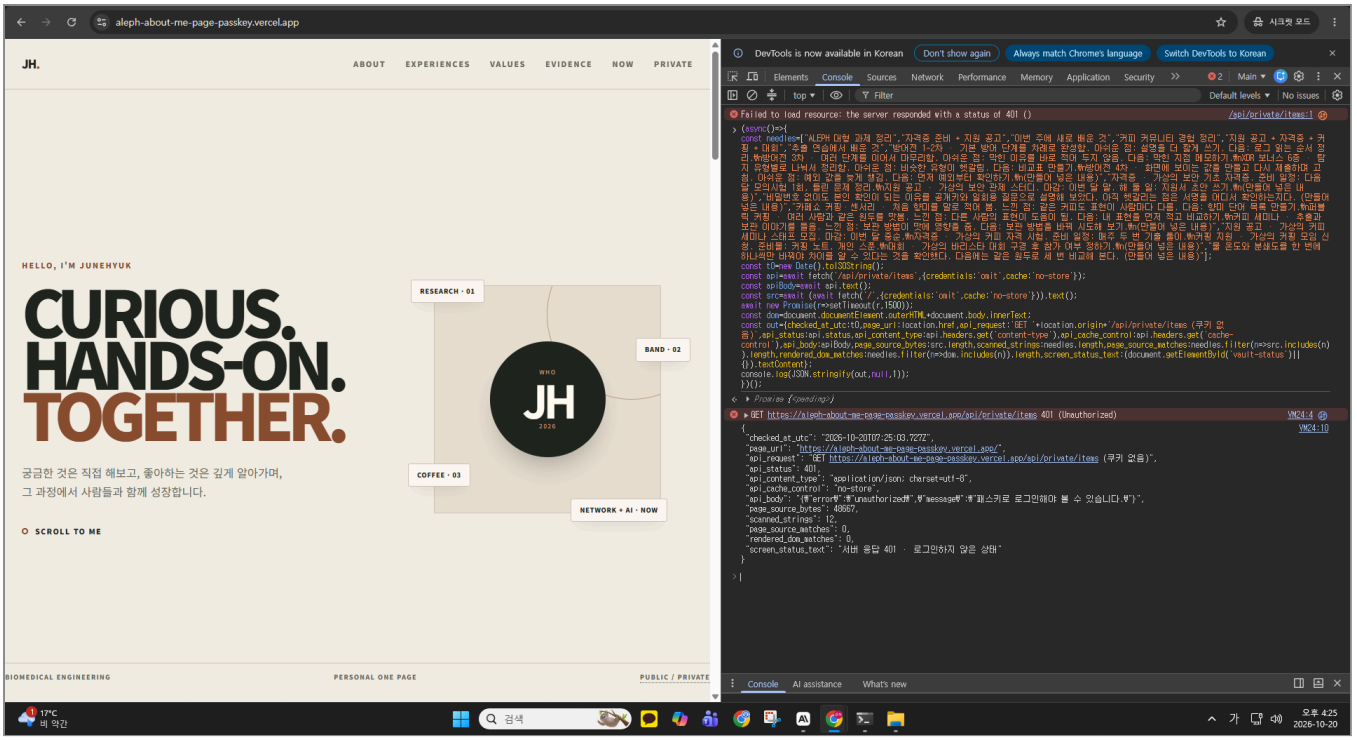
로그인 없이 /api/private/items 를 열면 401, 본문은 안내 문장뿐

로그인 없이 받은 응답(요청: GET /api/private/items, 쿠키 없음) — 상태 401, 본문 `{"error":"unauthorized","message":"패스키로 로그인해야 볼 수 있습니다."}`. 페이지 소스·화면에서 비공개 문장 0/12건.



위 결과가 나온 콘솔 화면(점검 명령어와 출력 결과, 401 줄 포함)

정리: api_status 401 · api_content_type application/json · api_cache_control no-store · scanned_strings 12 · page_source_matches 0 · rendered_dom_matches 0 · screen_status_text “서버 응답 401”. (점검 시각 2026-10-20T05:16:15Z, 쿠키 없음)



수정이 모두 끝난 뒤 다시 한 시크릿 창 점검: 자료 API 401, 비공개 문장 0/12건

② 등록 요청과 응답 기록, 서버에 저장된 공개키, 패스키 목록 화면

계정 B 등록의 요청·응답 기록(화면의 “요청·응답 기록 보기”에서 복사). 요청 본문에 개인키는 없습니다.


```
[
 {
  "단계": "1. 질문 요청 → 응답 200",
  "시각": "오후 3:17:37",
  "요청": {
   "accountId": "account-b",
   "name": "B 1st passkey"
  },
  "응답": {
   "challenge": "2RkvKdWC9meg6SQxdWYnEmeO_KrevTIpMMfxwFv3o4I",
   "rp": {
    "name": "ALEPH 소개 페이지",
    "id": "aleph-about-me-page-passkey.vercel.app"
   },
   "user": {
    "id": "YWNjb3VudC1i",
    "name": "account-b",
    "displayName": "계정 B (커피)"
   },
   "pubKeyCredParams": [
    {
     "type": "public-key",
     "alg": -7
    },
    {
     "type": "public-key",
     "alg": -257
    },
    {
     "type": "public-key",
     "alg": -8
    }
   ],
   "timeout": 60000,
   "attestation": "none",
   "excludeCredentials": [],
   "authenticatorSelection": {
    "residentKey": "required",
    "requireResidentKey": true,
    "userVerification": "preferred"
   }
  }
 },
 {
  "단계": "2. 기기의 답 전송 → 응답 201",
  "시각": "오후 3:17:52",
  "요청": {
   "name": "B 1st passkey",
   "credential": {
    "id": "GUC1V99lWv_RklAp-X5nPA",
    "rawId": "GUC1V99lWv_RklAp-X5nPA",
    "type": "public-key",
    "response": {
     "clientDataJSON": "eyJOeXBlIjoid2ViYXVOaG4uY3Jl…(216자)",
     "attestationObject": "o2NmbXRkbm9uZWdhdHRTdG1OoGhh…(238자)",
     "transports": [
      "hybrid",
      "internal"
     ]
    }
   }
  },
  "응답": {
   "ok": true,
   "account": {
    "id": "account-b",
    "label": "계정 B (커피)"
   },
   "stored": {
    "name": "B 1st passkey",
    "created_at": "2026-10-20T06:17:55.857546+00:00",
    "credential_id": "GUC1V99lWv_RklAp-X5nPA",
    "public_key": "MFkwEwYHKoZIzj0CAQYIKoZIzj0D…(122자)",
    "algorithm": "ES256 (P-256)",
    "counter": 0
   },
   "note": "서버에는 위 공개키만 저장됩니다. 개인키는 이 기기…(47자)"
  }
 }
]
```



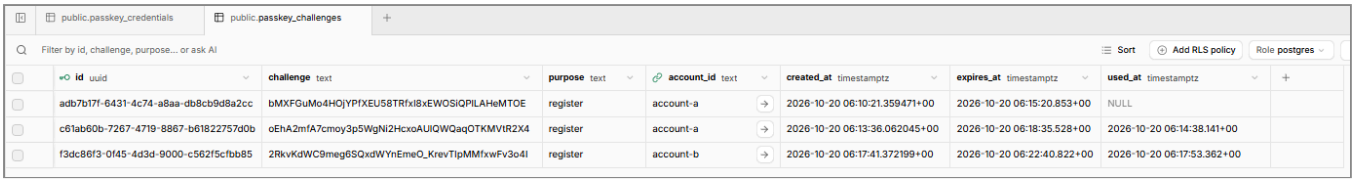
계정 A 등록 직후



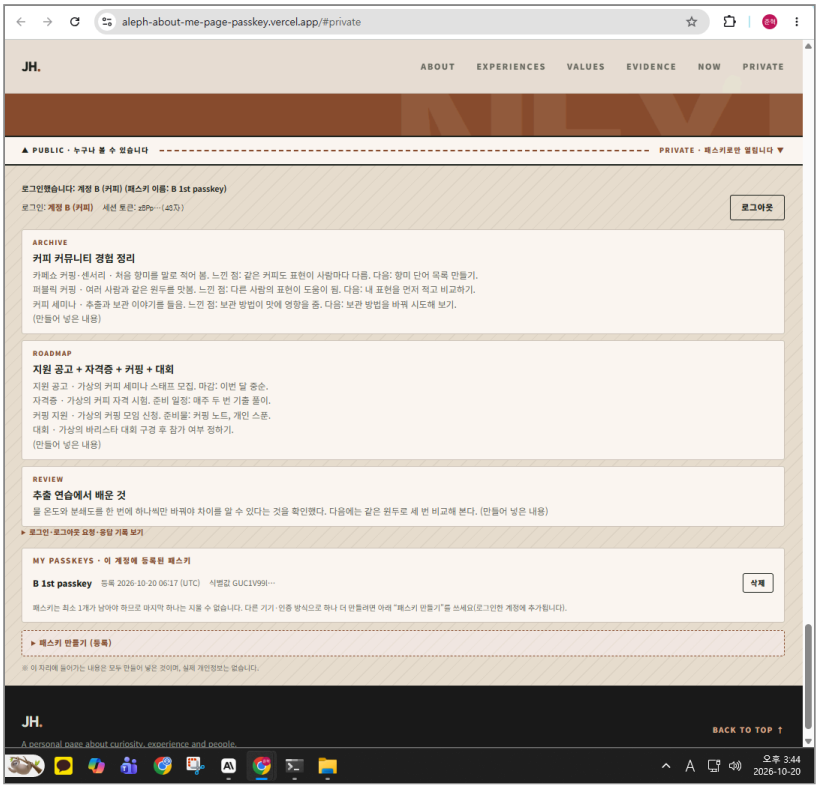
계정 B 등록 직후



서버(Supabase)에 저장된 것은 공개키(public_key)와 이름뿐. 비밀번호·개인키 열은 없음

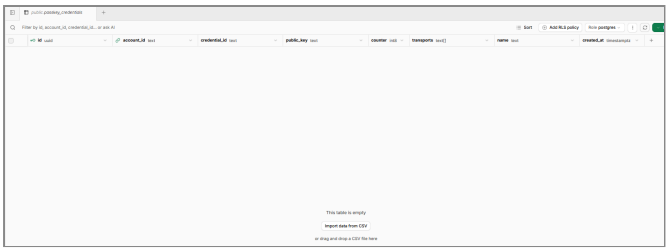


서버가 낸 일회용 질문 3건: 모두 다른 값. 쓴 질문은 used_at이 찍힘(취소한 시도는 NULL)



패스키 목록 화면(이름·등록 날짜·식별값)

등록 도중 취소: 서버로 아무것도 보내지 않았고 passkey_credentials는 0건. 이미 패스키가 있는 계정에 로그인 없이 등록 시도 → 403.



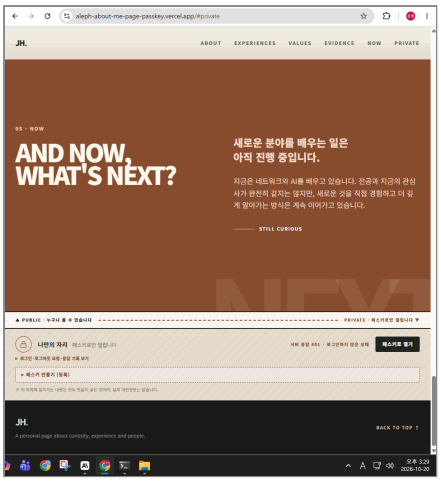
취소 직후 passkey_credentials: 0건



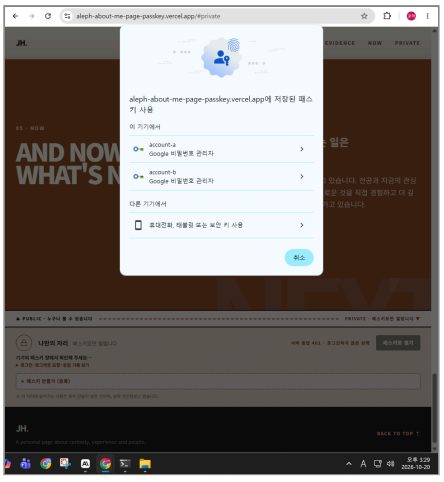
로그인 없이 등록 시도 → 403

개인키는 이 PC의 Chrome이 로그인된 **Google 비밀번호 관리자**에 저장했고, 서버에는 공개키만 있습니다.

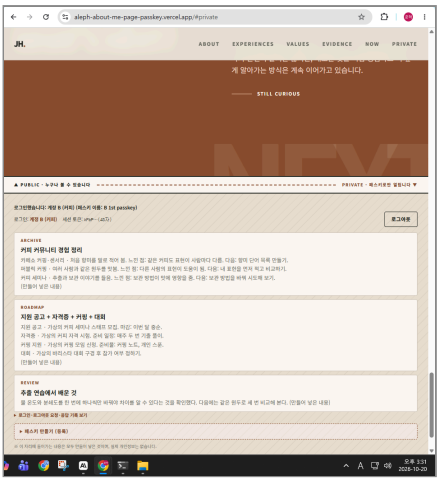
③ 성공한 로그인 요청, 실패한 요청, 이미 쓴 질문을 재사용한 요청과 거절 응답



로그인 전: 잠김, 비밀번호 입력칸 없음



기기의 패스키 선택 창



로그인 후: 계정 B 자료 3개, 토큰은 앞 4글자만

성공한 로그인 요청·응답(질문 요청 → 기기 서명 → 서버 응답 200). 토큰은 마스킹.


```
[
 {
  "단계": "1. 질문 요청 → 응답 200",
  "시각": "오후 3:29:42",
  "응답": {
   "challenge": "DmJP5AUwoFwzY-bGhiwnEhVoBpureug-CT_4w79zJ-Y",
   "rpId": "aleph-about-me-page-passkey.vercel.app",
   "timeout": 60000,
   "userVerification": "preferred",
   "allowCredentials": []
  }
 },
 {
  "단계": "2. 기기의 서명 전송 → 응답 200",
  "시각": "오후 3:30:11",
  "요청": {
   "credential": {
    "id": "GUC1V99lWv_RklAp-X5nPA",
    "rawId": "GUC1V99lWv_RklAp-X5nPA",
    "type": "public-key",
    "response": {
     "clientDataJSON": "eyJ0eXBlIjoid2ViYXV0aG4uZ2V0···(358자)",
     "authenticatorData": "tlIfqw_H8uK6OUuW5uW_lw41Jov3···(50자)",
     "signature": "MEUCIFYyu4RFrppUOm9q2AJv1aRx···(95자)",
     "userHandle": "YWNjb3VudC1i"
    }
   }
  },
  "응답": {
   "ok": true,
   "account": {
    "id": "account-b",
    "label": "계정 B (커피)"
   },
   "passkey": {
    "name": "B 1st passkey"
   },
   "session": {
    "token_preview": "kFbP···(43자)",
    "expires_in_hours": 8,
    "where": "HttpOnly 쿠키(화면 스크립트는 읽을 수 없음···(42자)"
   },
   "counter": 0
  }
 }
]
```




token_hash text	account_id text	created_at timestamptz	expires_at timestamptz
ec9c600f0698099f77fb53290ad5ec0a64ddceacae623da09af67c7665ed94e9	account-b	2026-10-20 06:30:14.693149+00	2026-10-20 14:30:14.126+00

로그인 중 passkey_sessions: 1행. token_hash는 토큰의 해시(원문 아님)

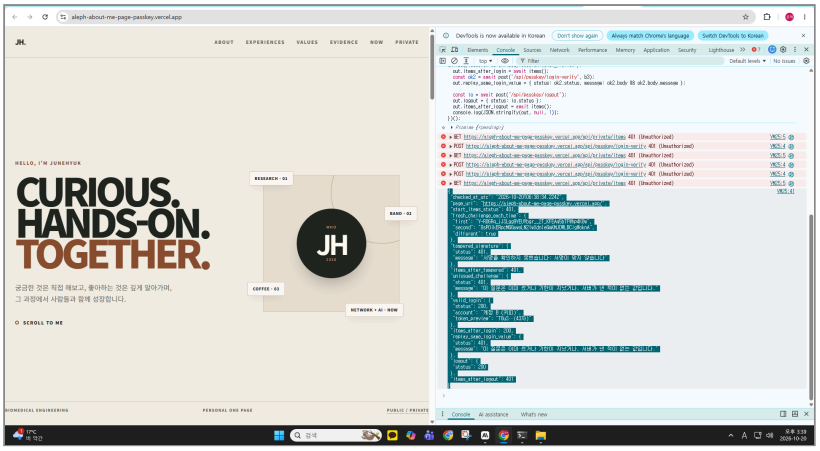


id uuid	account_id text	credential_id text	public_key text	counter int8	transports text[]	name text	created_at timestamptz
2f5f9c1a-a9d1-490c-addd-3ecc28fa1482	account-b	GUC1V99lWv_RklAp-X5nPA	MFkwEwYHKoZIzj0CAQYIKoZIzj0DAQcDQgAEThhpP86N04dLS2OoufBH	0	["hybrid","internal"]	B 1st passkey	2026-10-20 06:17:55.857546+00
382a23be-627c-44ed-a067-4f1817239863	account-a	2hA0sIVGMQz6mb_zAr5IyQ	MFkwEwYHKoZIzj0CAQYIKoZIzj0DAQcDQgAE4-aEn0p28QWmjhiqFRK01	0	["hybrid","internal"]	A 1st passkey	2026-10-20 06:14:40.324645+00

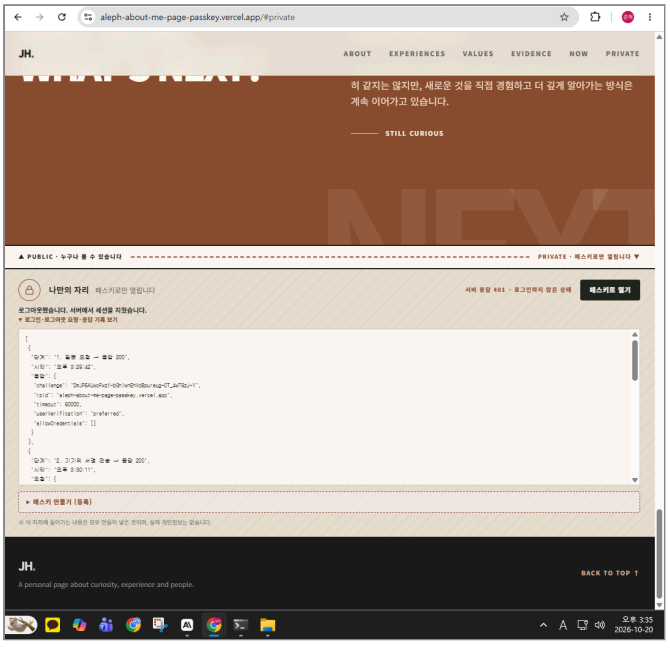
서명 횟수(counter)는 0 — 동기화 패스키는 0을 보냄

실패한 요청과 이미 쓴 질문의 재사용(배포 주소 콘솔 스크립트): 망가뜨린 서명 401, 서버가 낸 적 없는 질문 401, 같은 로그인 값(이미 쓴 질문) 재전송 401, 질문은 요청마다 새 값, 로그아웃 후 자료 요청 401.

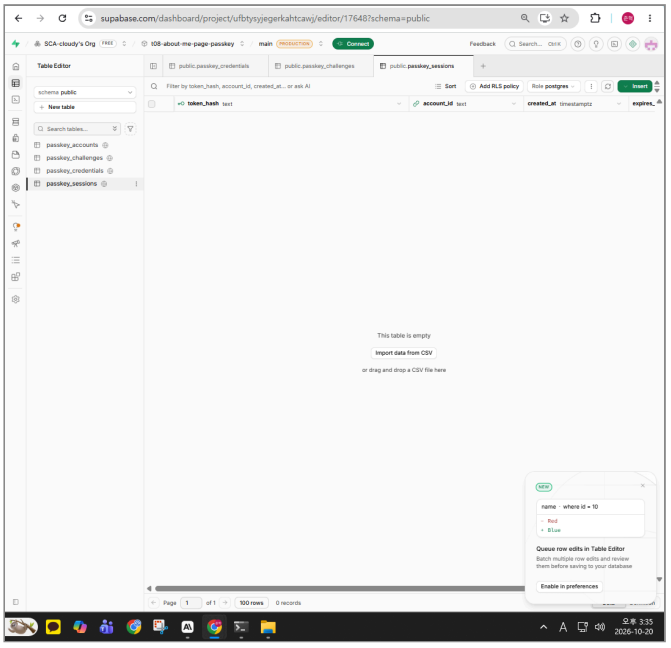

```
{
 "checked_at_utc": "2026-10-20T06:38:34.224Z",
 "page_url": "https://aleph-about-me-page-passkey.vercel.app/",
 "start_items_status": 401,
 "fresh_challenge_each_time": {
  "first": "Y-RO6Rq_jJSLgg9YEUYbgr__2T_KFEAq5bTFWhp4K8w",
  "second": "OsPOikERpcMGGawoLN21wXdnIeGmKMJDWLBCigWoknA",
  "different": true
 },
 "tampered_signature": {
  "status": 401,
  "message": "서명을 확인하지 못했습니다: 서명이 맞지 않습니다"
 },
 "items_after_tampered": 401,
 "unissued_challenge": {
  "status": 401,
  "message": "이 질문은 이미 썼거나 기한이 지났거나, 서버가 낸 적이 없는 값입니다."
 },
 "valid_login": {
  "status": 200,
  "account": "계정 B (커피)",
  "token_preview": "T8uS…(43자)"
 },
 "items_after_login": 200,
 "replay_same_login_value": {
  "status": 401,
  "message": "이 질문은 이미 썼거나 기한이 지났거나, 서버가 낸 적이 없는 값입니다."
 },
 "logout": {
  "status": 200
 },
 "items_after_logout": 401
}
```

위 결과가 나온 콘솔 화면(401 오류 줄이 거절의 증거)

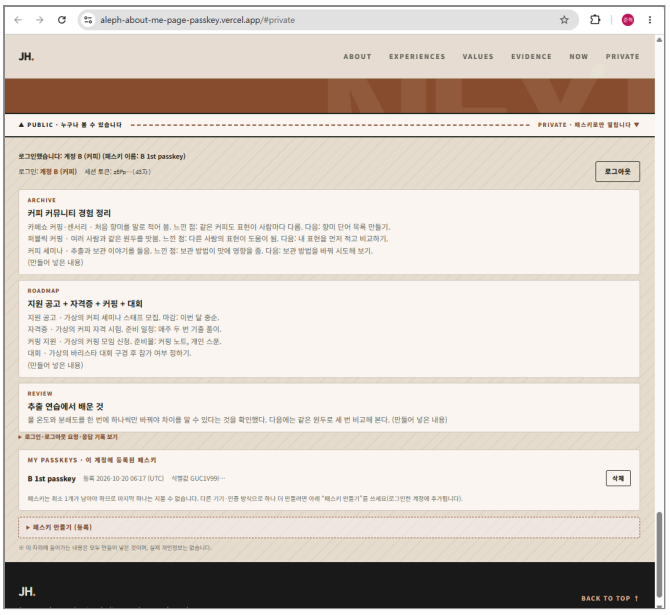


로그아웃 후 다시 잠김(서버 응답 401)

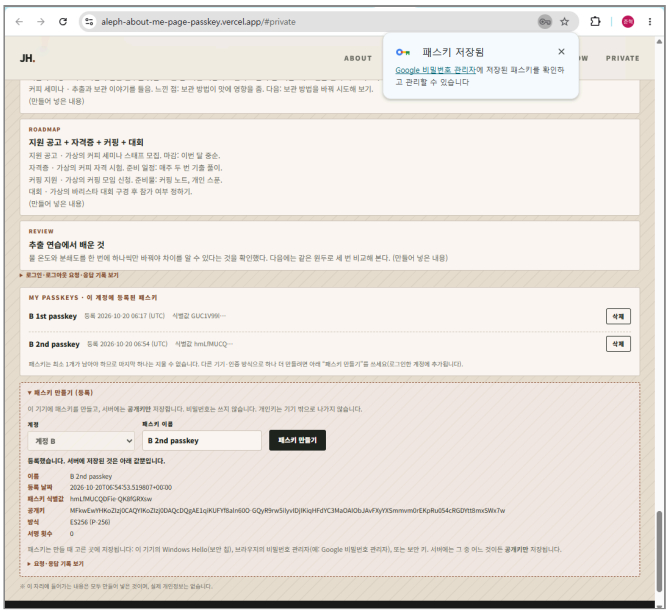


로그아웃 후 passkey_sessions 0행

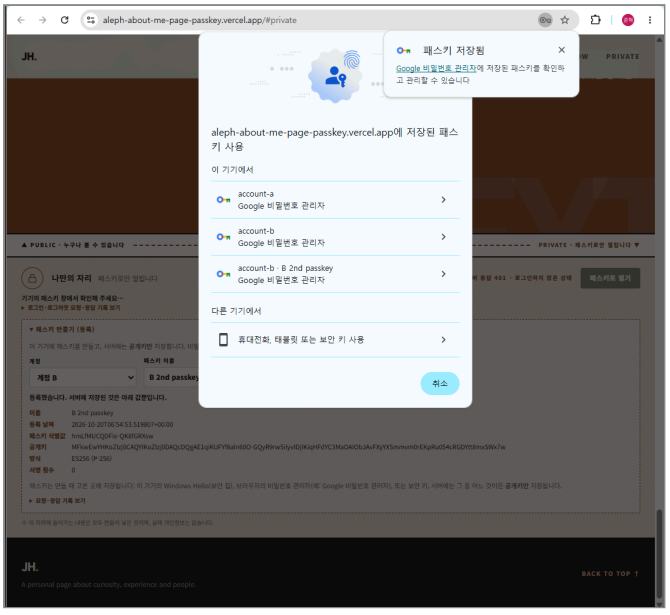
④ 패스키 두 개가 보이는 목록, 하나를 지운 뒤의 로그인 성공과 실패 기록



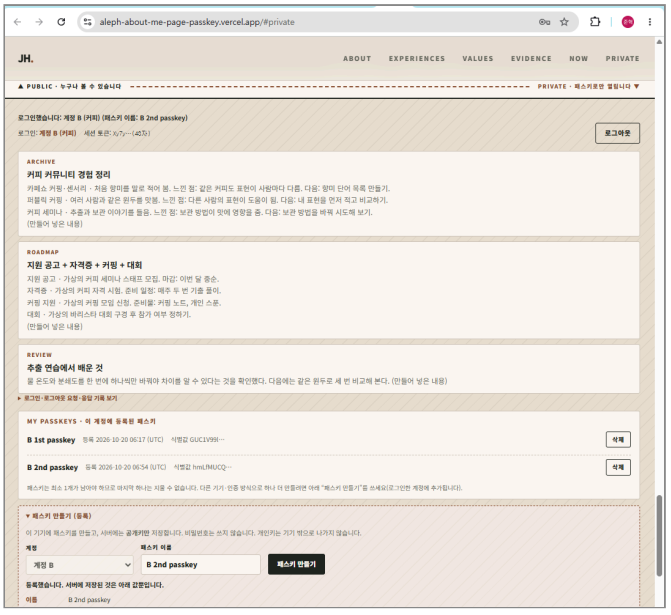
패스키 1개



두 번째 추가 후 목록에 2개

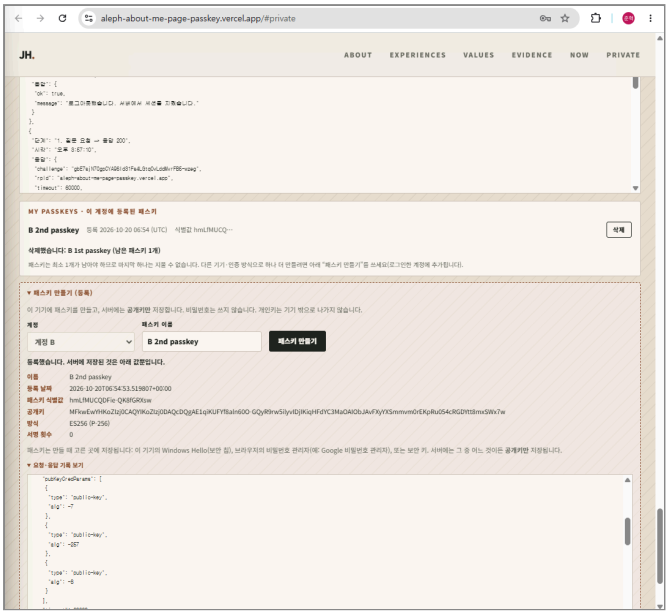


선택 창에 패스키가 따로 보임(…B 2nd passkey)

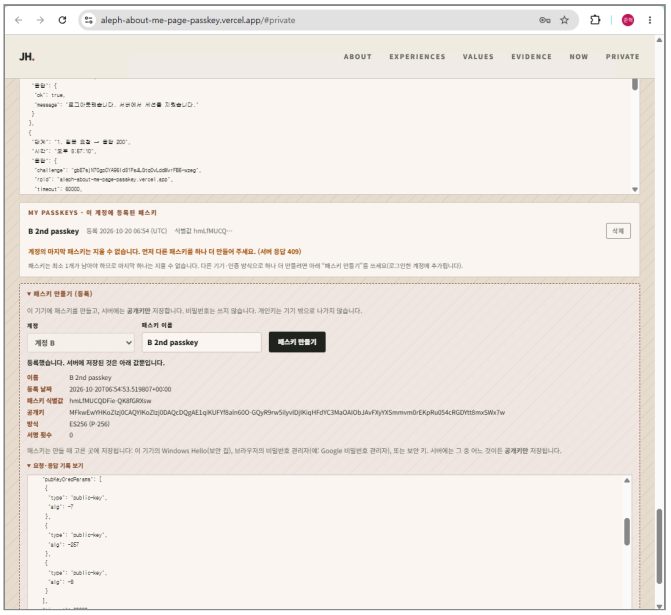


두 번째 패스키로 로그인 성공

```
[
 {
  "단계": "로그아웃 → 응답 200",
  "시각": "오후 3:57:05",
  "응답": {
   "ok": true,
   "message": "로그아웃했습니다. 서버에서 세션을 지웠습니다."
  }
 },
 {
  "단계": "1. 질문 요청 → 응답 200",
  "시각": "오후 3:57:10",
  "응답": {
   "challenge": "gbE7sjN7OgpCYA96ld31Fs4LGtqOvLddMvrFB5-wzeg",
   "rpId": "aleph-about-me-page-passkey.vercel.app",
   "timeout": 60000,
   "userVerification": "preferred",
   "allowCredentials": []
  }
 },
 {
  "단계": "2. 기기의 서명 전송 → 응답 200",
  "시각": "오후 3:57:35",
  "요청": {
   "credential": {
    "id": "hmLfMUCQDFie-QK8fGRXsw",
    "rawId": "hmLfMUCQDFie-QK8fGRXsw",
    "type": "public-key",
    "response": {
     "clientDataJSON": "eyJ0eXBlIjoid2ViYXVOaG4uZ2VO…(212자)",
     "authenticatorData": "tlIfqw_H8uK6OUuW5uW_lw41Jov3…(50자)",
     "signature": "MEUCIQCRuszxwuYymXb6VBGd6Vzx…(95자)",
     "userHandle": "YWNjb3VudC1iOjdlMzYzMjQwMDdm…(46자)"
    }
   }
  },
  "응답": {
   "ok": true,
   "account": {
    "id": "account-b",
    "label": "계정 B (커피)"
   },
   "passkey": {
    "name": "B 2nd passkey"
   },
   "session": {
    "token_preview": "Xy7y…(43자)",
    "expires_in_hours": 8,
    "where": "HttpOnly 쿠키(화면 스크립트는 읽을 수 없음…(42자)"
   },
   "counter": 0
  }
 }
]
```

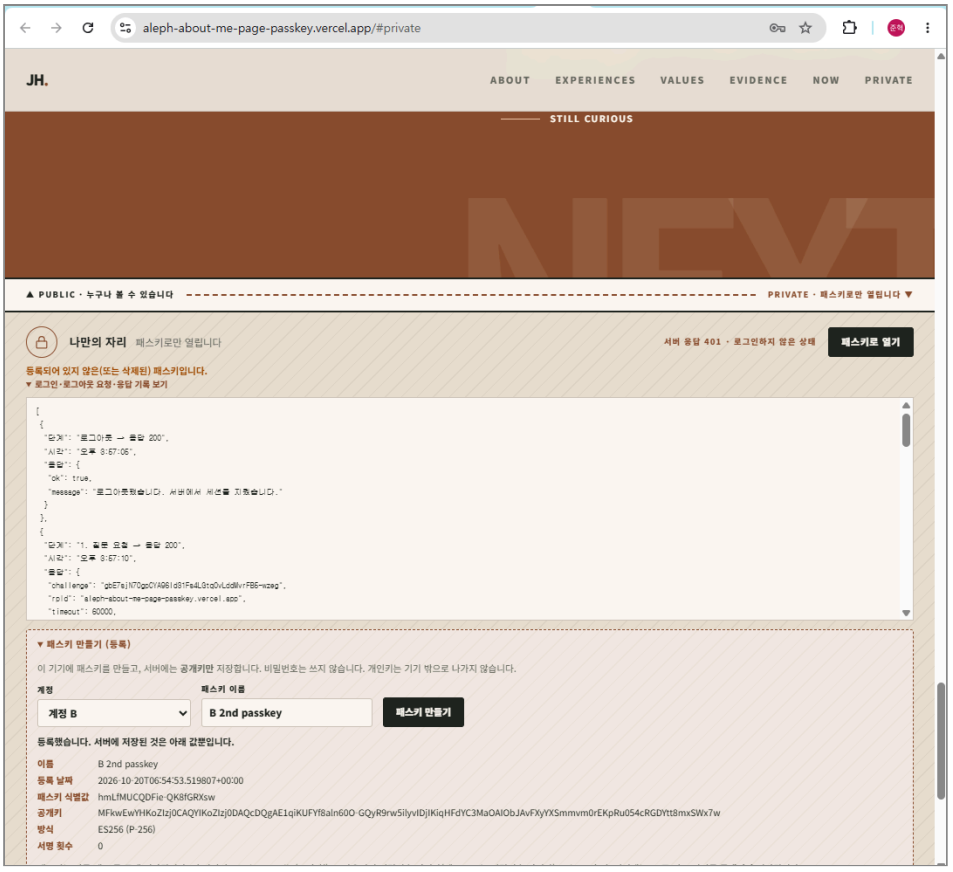



첫 번째 패스키 삭제 → 남은 1개



마지막 하나를 지우려 하면 서버가 거절(409)

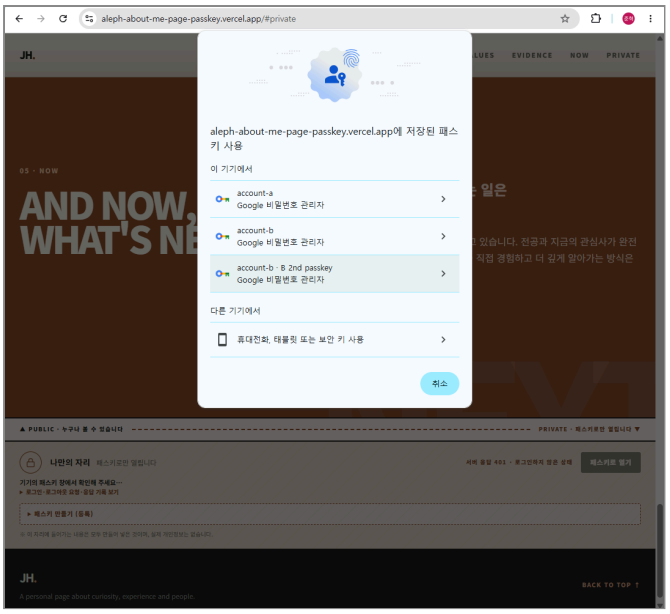
삭제 뒤 실패 기록 — 삭제한 패스키(1st)로 로그인 → 401 “등록되어 있지 않은(또는 삭제된) 패스키입니다.”



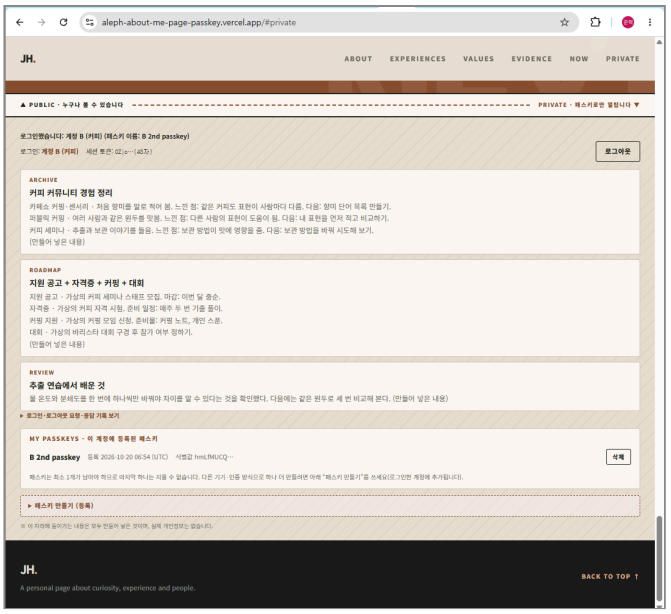
삭제한 패스키로 로그인 거절


```
[
 {
  "단계": "로그아웃 → 응답 200",
  "시각": "오후 4:02:04",
  "응답": {
   "ok": true,
   "message": "로그아웃했습니다. 서버에서 세션을 지웠습니다."
  }
 },
 {
  "단계": "1. 질문 요청 → 응답 200",
  "시각": "오후 4:02:19",
  "응답": {
   "challenge": "Vkdu32PEYYsSO-2zUekfc13RjOx8mGI2NwdFQaGgY2k",
   "rpId": "aleph-about-me-page-passkey.vercel.app",
   "timeout": 60000,
   "userVerification": "preferred",
   "allowCredentials": []
  }
 },
 {
  "단계": "2. 기기의 서명 전송 → 응답 401",
  "시각": "오후 4:02:30",
  "요청": {
   "credential": {
    "id": "GUC1V99lWv_RklAp-X5nPA",
    "rawId": "GUC1V99lWv_RklAp-X5nPA",
    "type": "public-key",
    "response": {
     "clientDataJSON": "eyJOeXBlIjoid2ViYXVOaG4uZ2VO…(212자)",
     "authenticatorData": "tlIfqw_H8uK6OUuW5uW_lw41Jov3…(50자)",
     "signature": "MEUCIQCgf1Bwc9OuSe8ZmqOXm1fE…(95자)",
     "userHandle": "YWNjb3VudC1i"
    }
   }
  },
  "응답": {
   "error": "login_failed",
   "message": "등록되어 있지 않은(또는 삭제된) 패스키입니다."
  }
 }
]
```


삭제 뒤 로그인 성공 기록 — 남은 패스키(B 2nd passkey, 식별값 hmLfMUCQ…)로 로그인 → 200 (오후 4:45~4:47), 이어서 로그아웃 200.

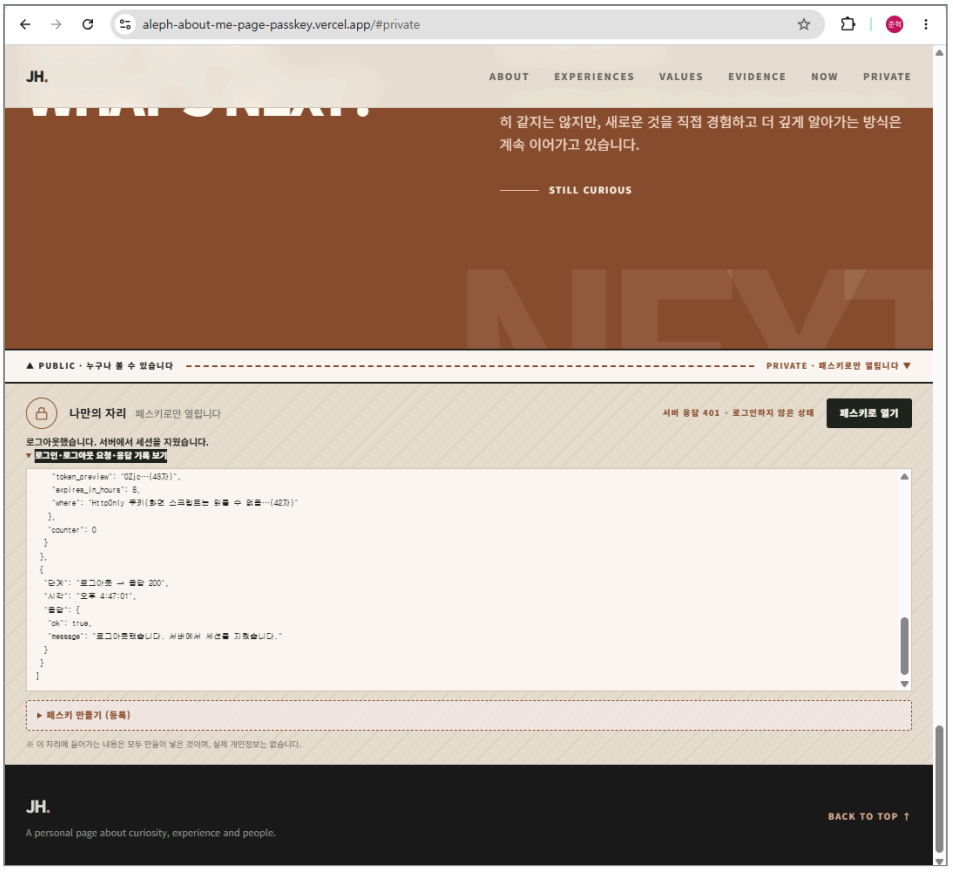


삭제 뒤 선택 창: 남은 패스키로 로그인 시도



로그인 성공, 목록에는 B 2nd passkey만


```
[
 {
  "단계": "1. 질문 요청 → 응답 200",
  "시각": "오후 4:45:42",
  "응답": {
   "challenge": "cRbXA1wi7b5AZvAg7O93_7yoliaNaTvqMAGpLG-gqo4",
   "rpId": "aleph-about-me-page-passkey.vercel.app",
   "timeout": 60000,
   "userVerification": "preferred",
   "allowCredentials": []
  }
 },
 {
  "단계": "2. 기기의 서명 전송 → 응답 200",
  "시각": "오후 4:45:58",
  "요청": {
   "credential": {
    "id": "hmLfMUCQDFie-QK8fGRXsw",
    "rawId": "hmLfMUCQDFie-QK8fGRXsw",
    "type": "public-key",
    "response": {
     "clientDataJSON": "eyJ0eXBlIjoid2ViYXV0aG4uZ2V0…(212자)",
     "authenticatorData": "tlIfqw_H8uK6OUuW5uW_lw41Jov3…(50자)",
     "signature": "MEUCIQCz2Qs3E59_xRpId0zdQ1PO…(95자)",
     "userHandle": "YWNjb3VudC1iOjdlMzYzMjQwMDdm…(46자)"
    }
   }
  },
  "응답": {
   "ok": true,
   "account": {
    "id": "account-b",
    "label": "계정 B (커피)"
   },
   "passkey": {
    "name": "B 2nd passkey"
   },
   "session": {
    "token_preview": "OZjc…(43자)",
    "expires_in_hours": 8,
    "where": "HttpOnly 쿠키(화면 스크립트는 읽을 수 없음…(42자)"
   },
   "counter": 0
  }
 },
 {
  "단계": "로그아웃 → 응답 200",
  "시각": "오후 4:47:01",
  "응답": {
   "ok": true,
   "message": "로그아웃했습니다. 서버에서 세션을 지웠습니다."
  }
 }
]
```



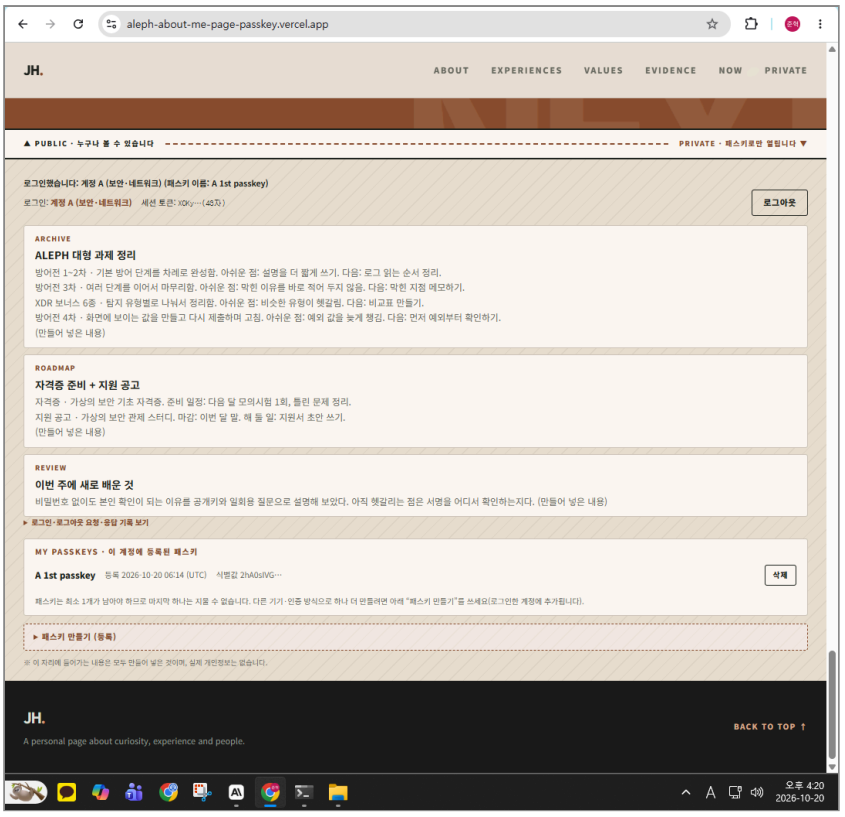
로그아웃 응답 200(오후 4:47:01), 다시 잠김

마지막 패스키까지 없어지면? 서버가 마지막 하나의 삭제를 거절합니다(409). 0개가 되면 주인 없는 계정이 되어 아무나 먼저 등록할 수 있게 되기 때문입니다.

⑤ 확인 네 가지의 요청과 응답, 인증 구현 설명서 여섯 항목

확인 네 가지: ㉮ 로그인 없이 비공개 자료 → 401 (위 ①) ㉯ 서명이 맞으면 200, 망가뜨리면 401 (위 ③) ㉰ 같은 질문 재사용: 처음 200, 둘째 401 (위 ③) ㉱ 다른 계정 건드리기 (아래).

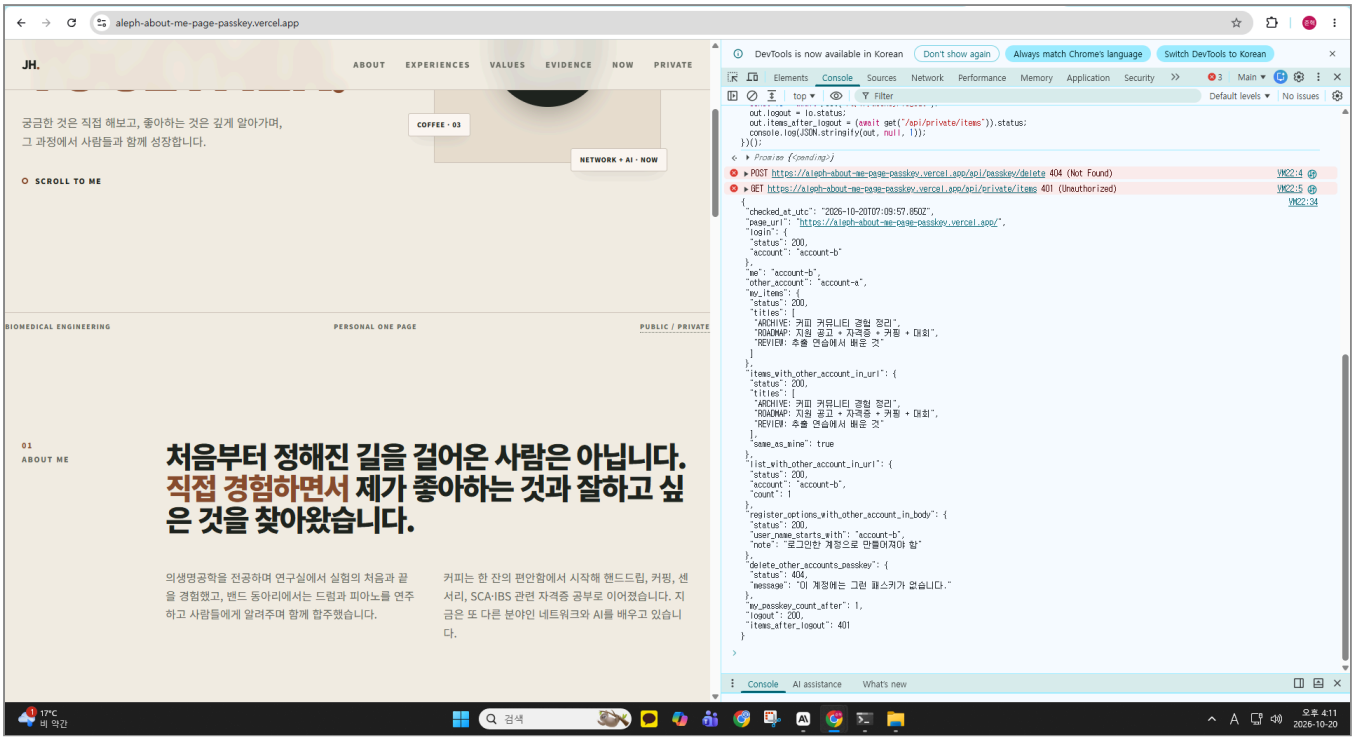
두 계정의 비공개 내용은 서로 다릅니다. 계정 A(보안·네트워크): ARCHIVE “ALEPH 대형 과제 정리”, ROADMAP “자격증 준비 + 지원 공고”, REVIEW “이번 주에 새로 배운 것”. 계정 B(커피): ARCHIVE “커피 커뮤니티 경험 정리”, ROADMAP “지원 공고 + 자격증 + 커핑 + 대회”, REVIEW “추출 연습에서 배운 것”.



계정 A로 로그인한 화면: A의 자료와 A의 패스키만

B로 로그인해서 A를 건드림 (주소·본문에 account-a를 적고, A의 패스키 id로 삭제 요청)

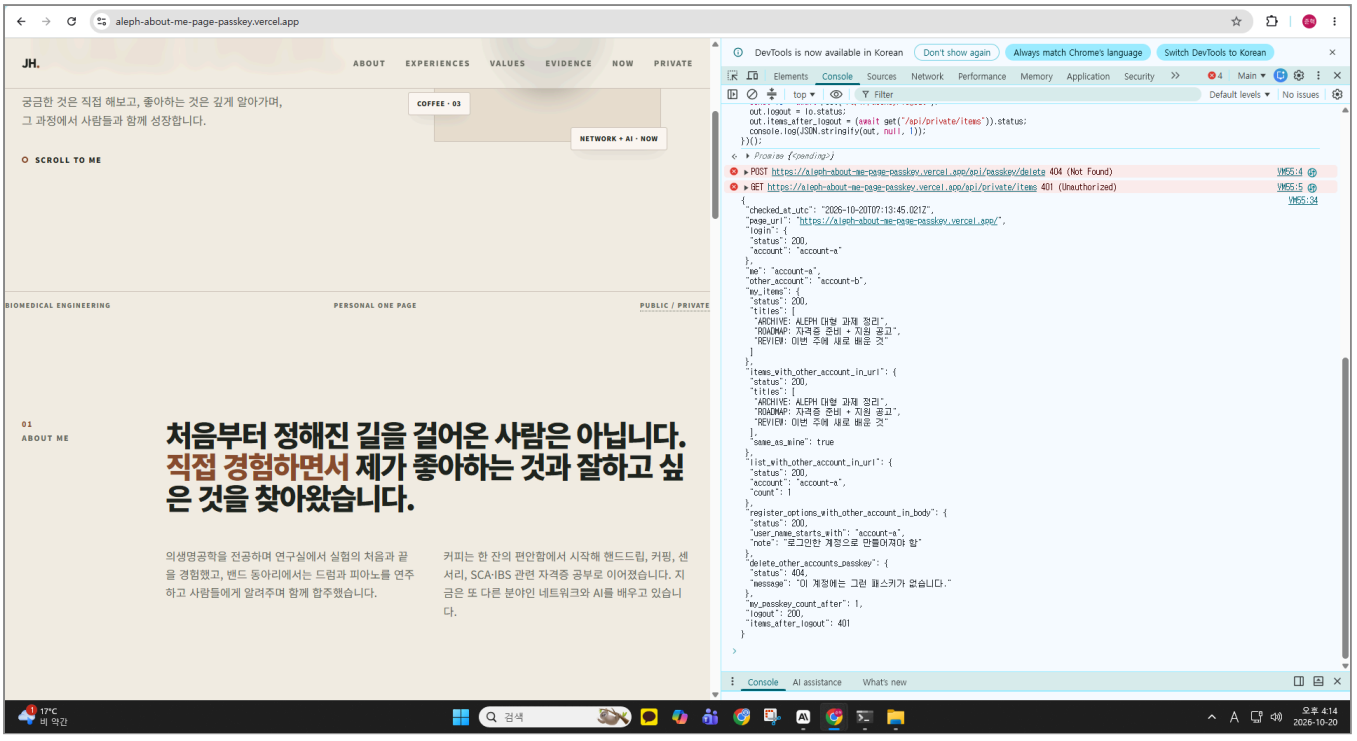

```
{
 "checked_at_utc": "2026-10-20T07:09:57.850Z",
 "page_url": "https://aleph-about-me-page-passkey.vercel.app/",
 "login": {
  "status": 200,
  "account": "account-b"
 },
 "me": "account-b",
 "other_account": "account-a",
 "my_items": {
  "status": 200,
  "titles": [
   "ARCHIVE: 커피 커뮤니티 경험 정리",
   "ROADMAP: 지원 공고 + 자격증 + 커핑 + 대회",
   "REVIEW: 추출 연습에서 배운 것"
  ]
 },
 "items_with_other_account_in_url": {
  "status": 200,
  "titles": [
   "ARCHIVE: 커피 커뮤니티 경험 정리",
   "ROADMAP: 지원 공고 + 자격증 + 커핑 + 대회",
   "REVIEW: 추출 연습에서 배운 것"
  ],
  "same_as_mine": true
 },
 "list_with_other_account_in_url": {
  "status": 200,
  "account": "account-b",
  "count": 1
 },
 "register_options_with_other_account_in_body": {
  "status": 200,
  "user_name_starts_with": "account-b",
  "note": "로그인한 계정으로 만들어져야 함"
 },
 "delete_other_accounts_passkey": {
  "status": 404,
  "message": "이 계정에는 그런 패스키가 없습니다."
 },
 "my_passkey_count_after": 1,
 "logout": 200,
 "items_after_logout": 401
}
```

실행 화면

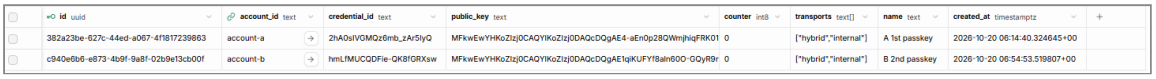
A로 로그인해서 B를 건드림


```
{
 "checked_at_utc": "2026-10-20T07:13:45.021Z",
 "page_url": "https://aleph-about-me-page-passkey.vercel.app/",
 "login": {
  "status": 200,
  "account": "account-a"
 },
 "me": "account-a",
 "other_account": "account-b",
 "my_items": {
  "status": 200,
  "titles": [
   "ARCHIVE: ALEPH 대형 과제 정리",
   "ROADMAP: 자격증 준비 + 지원 공고",
   "REVIEW: 이번 주에 새로 배운 것"
  ]
 },
 "items_with_other_account_in_url": {
  "status": 200,
  "titles": [
   "ARCHIVE: ALEPH 대형 과제 정리",
   "ROADMAP: 자격증 준비 + 지원 공고",
   "REVIEW: 이번 주에 새로 배운 것"
  ],
  "same_as_mine": true
 },
 "list_with_other_account_in_url": {
  "status": 200,
  "account": "account-a",
  "count": 1
 },
 "register_options_with_other_account_in_body": {
  "status": 200,
  "user_name_starts_with": "account-a",
  "note": "로그인한 계정으로 만들어져야 함"
 },
 "delete_other_accounts_passkey": {
  "status": 404,
  "message": "이 계정에는 그런 패스키가 없습니다."
 },
 "my_passkey_count_after": 1,
 "logout": 200,
 "items_after_logout": 401
}
```

실행 화면

시험 전·후 DB passkey_credentials(2행, id·날짜 그대로) — 삭제 요청이 다른 계정의 것을 지우지 않았음:



id uuid	account_id text	credential_id text	public_key text	counter int8	transports text[]	name text	created_at timestamptz
382a23be-627c-44ed-a067-4f1817239863	account-a	2hA0sIVGMQz6mb_zAr5lyQ	MFkwEwYHKoZIzj0CAQYIKoZIzj0DAQcDQgAE4-aEnOp28QWmjhiqFRK0t	0	["hybrid","internal"]	A 1st passkey	2026-10-20 06:14:40.324645+00
c940e6b6-e873-4b9f-9a8f-02b9e13cb00f	account-b	hmLfMUCQDFie-QK8fGRXsw	MFkwEwYHKoZIzj0CAQYIKoZIzj0DAQcDQgAE1qiKUFYf8aln6OO-GQyR9r	0	["hybrid","internal"]	B 2nd passkey	2026-10-20 06:54:53.519807+00

시험 전 (A 1행, B 1행)



id uuid	account_id text	credential_id text	public_key text	counter int8	transports text[]	name text	created_at timestamptz
382a23be-627c-44ed-a067-4f1817239863	account-a	2hA0sIVGMQz6mb_zAr5lyQ	MFkwEwYHKoZIzj0CAQYIKoZIzj0DAQcDQgAE4-aEr	0	["hybrid","internal"]	A 1st passkey	2026-10-20 06:14:40.324645+00
c940e6b6-e873-4b9f-9a8f-02b9e13cb00f	account-b	hmLfMUCQDFie-QK8fGRXsw	MFkwEwYHKoZIzj0CAQYIKoZIzj0DAQcDQgAE1qiKU	0	["hybrid","internal"]	B 2nd passkey	2026-10-20 06:54:53.519807+00

시험 후 (그대로)

인증 설명

① 무엇으로 붙였나

패스키(WebAuthn) 입니다. 브라우저의 `navigator.credentials.create()/get()`으로 기기가 열쇠 한 쌍을 만들고, 서버는 **공개키만** 저장해 로그인 때 서명을 확인합니다. 외부 라이브러리 없이 **Node.js 내장 `crypto`로 직접 구현**했습니다 (`api/_lib/webauthn.js`, `cbor.js`; 작업 환경에서 npm 레지스트리에 접속할 수 없었기 때문). 서버는 Vercel 서버 함수, 저장은 Supabase(Postgres)입니다. 비밀번호 입력칸은 어디에도 없습니다.

② 왜 이걸 골랐나

- 서버에 **비밀이 남지 않습니다.** 저장되는 것은 공개키뿐이라 DB가 유출돼도 그것으로 로그인할 수 없습니다.
- 서명 안에 **사이트 주소**가 들어가 가짜 사이트에서는 쓸 수 없습니다.
- 과제가 요구한 "비밀번호 없이 나만 들어가기"를 그대로 만족합니다.

③ 어디를 어떻게 고쳤나 (4가지 흐름)

흐름	고친 곳	하는 일
등록	`api/passkey/register-options.js`, `register-verify.js`, `index.html`(등록 칸)	서버가 일회용 질문을 만들어 보관 → 기기가 답함 → 서버가 질문·주소를 확인하고 **공개키만** 저장(이름 붙임). 취소하면 아무것도 저장하지 않음
로그인	`login-options.js`, `login-verify.js`, `api/_lib/session.js`, `index.html`(로그인 버튼)	요청마다 새 질문 → 서명 확인(저장된 공개키) → 질문은 그 순간 '사용됨' → 세션 토큰(쿠키, 서버엔 해시만)
접근 보호	`api/private/items.js`, `session.js`	쿠키의 세션으로 계정을 정하고 그 계정의 자료만 줌. 로그인 안 하면 401. 비공개 내용은 페이지 소스가 아니라 서버 파일(`api/_lib/private-data.js`)에만 있음
관리·로그아웃	`logout.js`, `list.js`, `delete.js`	로그아웃은 서버의 세션 기록 삭제, 패스키 목록(이름·날짜), 삭제(내 계정 것만, 마지막 하나는 거절)

④ 확인 네 가지 — 성공과 거절 나란히

확인	성공	거절	증거
비공개 자료	로그인 후 자기 계정 자료 3개 보임(200)	로그인 전·로그아웃 후 401, 페이지 소스에 문장 0건	card1, card3, card5
로그인 서명	올바른 서명 → 200, 세션 시작	일부러 망가뜨린 서명 → 401 "서명이 맞지 않습니다", 서버가 낸 적 없는 질문 → 401	card3/console-result.json
질문 재사용	처음 보낸 로그인 값 → 200	같은 값을 다시 보내면 401 "이미 썼거나…"	card3/console-result.json
다른 계정	내 계정 자료·패스키만 보임·삭제됨	주소·본문에 상대 계정을 적어도 내 것만 옴, 상대 패스키 삭제 → 404, DB 개수 그대로	card5 (B→A, A→B 양쪽)

덧붙임: 삭제한 패스키로 로그인 → 401(card4), 계정의 마지막 패스키 삭제 → 409(card4), 이미 주인 있는 계정에 로그인 없이 패스키 등록 → 403(card2).

거절이 일어나는 소스 위치: - 로그인 안 함 → `api/private/items.js:11` - 계정을 정하는 곳(세션만 봄) → `api/_lib/session.js:30` - 서명 확인 → `api/_lib/webauthn.js:139`, 질문 재사용 → `api/passkey/login-verify.js:30` - 남의 패스키 삭제 거절 → `api/passkey/delete.js:24`, 마지막 하나 → `delete.js:25`

⑤ AI와 나

AI: 등록·로그인·세션·삭제 코드와 서명 확인 로직, 자동 시험, 기록 문서를 작성했습니다. **나**: 무엇을 비공개로 둘지·두 계정에 무엇을 넣을지 정하고, 실제 기기(Google 비밀번호 관리자)에서 등록·로그인·삭제·다른 계정 시험을 직접 실행했으며, 화면·DB 결

과를 눈으로 확인해 AI가 말한 것과 맞는지 판단했습니다. 시험 중 서버 오류(500)와 같은 기기에서 패스키가 덮어쓰이는 문제는 직접 해 보고 나서야 드러났고, 그에 맞춰 고쳤습니다(docs/TESTLOG.md).

⑥ 아직 못 막은 것

1. **로그인 시도 횟수 제한이 없습니다.** 질문 요청과 로그인 시도를 무제한으로 보낼 수 있습니다.
2. **삭제한 패스키로 이미 시작한 세션은 로그아웃하거나 8시간이 지날 때까지 유효합니다.** 패스키를 지워도 그 계정의 열린 세션을 바로 끊지 않습니다.
3. **주인 없는 계정은 먼저 등록하는 사람이 차지합니다.** 처음 패스키를 만들 때는 로그인이 필요 없습니다(지금은 두 계정 모두 등록 완료라 막혀 있음).
4. **직접 구현한 확인 코드입니다.** 검증된 라이브러리가 아니고 기기 종류를 증명하는 정보(attestation)는 확인하지 않습니다. 서명 횟수를 늘리지 않는 동기화 패스키는 복제 감지가 되지 않습니다.
5. **‘마지막 패스키 삭제 금지’는 두 삭제 요청이 정확히 동시에 오면 경쟁할 수 있습니다.**(개수를 확인한 뒤 지우는 두 단계라서)
6. **비공개 내용이 공개 소스 저장소에 들어 있습니다.** 과제용으로 만든 내용이라 괜찮지만, 진짜 비밀이라면 이런 식으로 두면 안 됩니다.

시험 기록

시각은 모두 2026-10-20(KST). 배포 주소 시험은 사람이 일반 Chrome 창에서 직접 했고(저장 위치: Google 비밀번호 관리자), 화면·DB 캡처와 콘솔 기록은 `evidence/`에 있습니다. 개발 환경에서는 가상 인증기로 같은 흐름을 자동 시험했습니다.

1. 개발 환경 자동 시험 (가상 인증기, 메모리 저장)

스크립트	결과	주요 내용
`scripts/test_card2.py`	20/20 통과	취소하면 0건 저장, 질문이 요청마다 다름, 질문 재사용 거절, 출처 변조 거절, 개인키가 요청·응답에 없음
`scripts/test_card3.py`	22/22 통과	비밀번호 칸 없음, 로그인 후 자기 계정 자료만, 토큰 마스킹·HttpOnly, 같은 로그인 값 재전송 거절, 로그아웃 후 옛 토큰 401
`scripts/test_card4.py`	21/21 통과	같은 기기에 패스키 2개(덮어쓰지 않음), 목록, 삭제, 삭제한 것으로 로그인 거절, 마지막 하나 409, 남의 패스키 삭제 404·개수 그대로

2. 배포 주소 시험

시각	한 일	기대	결과	증거
(카드 1)	시크릿 창에서 공개 페이지 · `/api/private/items`	첫 화면 공개, 자료 API 401, 페이지 소스에 비공개 문장 0건	통과	evidence/card1/
15:06~15:10	등록 시도 중 취소	안내만, DB 0건	통과	evidence/card2/deployed/
15:14	계정 A 패스키 등록	DB에 공개키 1건	통과	〃
15:17	계정 B 패스키 등록	DB에 공개키 1건	통과	〃
15시대	패스키가 이미 있는 계정에 로그인 없이 등록	403	통과	〃
15:29~15:35	계정 B로 로그인·로그아웃	자료 3개, 토큰 마스킹, 세션 DB 1건 → 로그아웃 후 0건	통과	evidence/card3/deployed/
15:38	콘솔 스크립트(망가뜨린 서명·낸 적 없는 질문·재전송·로그아웃)	401·401·401·401	통과	evidence/card3/deployed/console-result.json
15:54	로그인 상태에서 두 번째 패스키 추가	목록 2개(이름·날짜)	통과	evidence/card4/deployed/
15:57	두 번째 패스키로 로그인	200, 패스키 이름 B 2nd passkey	통과	〃
15:59~16:00	첫 번째 패스키 삭제 → 마지막 하나 삭제	남은 1개 → 409	통과	〃
16:02	삭제한 패스키로 로그인	401 "등록되어 있지 않은(또는 삭제된)"	통과	〃
16:09	계정 B로 로그인해 A를 건드림	주소·본문에 A를 적어도 B 것만, A 패스키 삭제 404	통과	evidence/card5/deployed/console-B-touches-A.*
16:13	계정 A로 로그인해 B를 건드림	같음	통과	evidence/card5/deployed/console-A-touches-B.*
16:06 → 16:16	시험 전·후 DB `passkey_credentials`	2행, id·날짜 그대로	통과	db-credentials-before/after.png
16:20	계정 A 로그인 화면	A의 자료 3개(보안), 패스키 `A 1st passkey`	통과	page-logged-in-A.png
16:45	패스키 하나(B 1st)를 지운 뒤, 남은 B 2nd passkey로 로그인 → 로그	로그인 200(식별값 hmLfMUCQ…), 로그아웃	통과	evidence/card4/deployed/*after-delete*

시각	한 일	기대	결과	증거
	아웃	200		
16:25	최종 점검: 시크릿 창에서 공개 페이지(코드 변경 뒤 다시)	자료 API 401, 페이지 소스·화면에 비공개 문장 0/12건	통과	evidence/final/

3. 시험 중 있었던 문제

- 15:06 첫 등록 요청이 500: 서버 키에 표 사용 권한이 없었음(`db GET passkey_accounts -> 403`). SQL로 서버 키에만 권한을 줘서 해결(`db/schema.sql`, 커밋 02b913b).
- 두 번째 패스키를 같은 Google 비밀번호 관리자에 만들 수 없었음: 사용자 식별값이 같으면 새 패스키가 옛 것을 덮어쓰기 때문. 패스키마다 식별값을 다르게 바꿈(커밋 65cee61). 이 PC에는 Windows Hello가 없었고 PC 설정을 바꾸지 않기로 해서 이 방법을 택함.
- 외부 라이브러리(SimpleWebAuthn 등)를 쓰려 했으나 작업 환경에서 npm 레지스트리에 접속할 수 없어, Node 내장 `crypto`로 직접 구현함.